

User Authentication System Requirements

1. User Registration

- Users should be able to register with email and password
- Email validation is required
- Password must be at least 8 characters with special characters
- Duplicate email addresses should not be allowed

2. User Login

- Users should be able to login with email/password combination
- Failed login attempts should be tracked and logged
- Account lockout after 5 consecutive failed attempts
- Session management with automatic timeout after 30 minutes

3. Password Reset

- Users should be able to reset password via email
- Reset links should expire after 24 hours
- Old passwords should not be reusable

4. User Profile Management

- Users should be able to update their profile information
- Profile picture upload functionality
- Email change requires verification

5. Security Requirements

- All passwords must be encrypted using bcrypt
- HTTPS must be used for all authentication endpoints
- Rate limiting on login attempts
- CSRF protection on all forms

6. API Requirements

- RESTful API endpoints for all authentication operations
- JWT token-based authentication for API access
- API rate limiting and throttling

7. Database Requirements

- User data should be stored securely
- Audit trail for all authentication events
- Data backup and recovery procedures